

Web-Security und Intrusion Prevention

SoSe 26

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 3 Path Traversal

Lernziele: Path-Traversal Angriffe verstehen und verhindern

Abgabetermin wird bekannt gegeben

Aufgabe 1: Verstehen der Webanwendung

Entpacken Sie die zip-Datei in einem Verzeichnis Ihrer Wahl. Darin finden Sie eine Python Webanwendung und ein Ordner mit dem Namen files. Sie können gerne eigene Dateien in diesen Ordner kopieren.

App.py

Sehen Sie sich das Python-Skript app.py an. Die Webanwendung wird folgendes machen:

- Wenn kein GET-Parameter übertragen wird, such das Skript im Unterordner files nach allen Dateien.
- Für jede gefunden Datei wird ein Link generiert, um die Datei im Browser zu öffnen: Hierfür wird ein GET-Parameter „files“ verwendet. Dieser wird auf den Pfad der aktuellen Datei gesetzt.
- Wird die Anwendung mit dem GET-Parameter „files“ geöffnet, gibt das Skript den Inhalt der angegebenen Datei zurück.

Starten Sie app.py mit python.

Aufgabe 2: Die Webanwendung ausnutzen

Manipulieren Sie den Aufruf derartig, dass Sie den Inhalt der Datei passwd im Ordner etc sehen? Wie sieht der Aufruf aus? Versuchen Sie auch andere Dateien aus.

Aufgabe 3 Sichern Sie die Anwendung ab

Ändern Sie die Anwendung so, dass ein Path Traversal Angriff nicht mehr möglich ist.

- Ein erster Versuch: Prüfen Sie, dass nur Dateien angezeigt werden, deren Pfad mit „files/“ beginnt.
- Können Sie nun immer noch den Angriff durchführen? Was ist mit relativen Pfaden?

Benutzen Sie die Python Methode os.path.realpath(), um zweifelsfrei sicherzustellen, dass nur Dateien in files/ angezeigt werden. Wenn Sie mit dieser Methode die Prüfung korrekt implementieren, schützt dies auch vor Path-Traversal Angriffe mit symlinks.

Abgaben im Praktikum zu zeigen:

- Zeigen Sie einen Aufruf der Datei passwd im Ordner etc.
- Zeigen Sie Ihren ersten Versuch zum Schutz vor Path Traversal mit Code und fehlgeschlagenem Aufruf. Zeigen Sie einen Erfolgreichen Path Traversal Angriff mit einem relativen Pfad.
- Zeigen Sie den Code zum vereiteln relativer Traversal Angriffe und einen verhinderten Aufruf.